Use WSO2 Identity Server as the Login for the API Manager Portals (OIDC)

Introduction

By default, users log in to the API Manager Publisher and Developer Portal with accounts stored in API Manager. In this lab you make WSO2 Identity Server 7.3.0 the login for both portals, using OpenID Connect (OIDC):

1. A user opens the Publisher or the Developer Portal and is sent to the Identity Server login page.
2. After login, Identity Server sends the user's **groups** back to API Manager in the ID token.
3. API Manager creates the user locally the first time (Just-In-Time provisioning) and maps each group to an API Manager role.

Identity Server group	**API Manager role**	**Test user**	**What the user can do**
apim_creators	Internal/creator	chris	Create APIs in the Publisher
apim_publishers	Internal/publisher	paula	Publish APIs in the Publisher
apim_subscribers	Internal/subscriber	sam	Subscribe to APIs in the Developer Portal

Based on the WSO2 API Manager 4.7.0 guide "Configure Identity Server as External IDP with OIDC". Time: about 45 minutes.

CC BY 4.0

Prerequisites

1. WSO2 API Manager 4.7.0 and WSO2 Identity Server 7.3.0, each extracted into its own folder (`<APIM_HOME>` and `<IS_HOME>` below).
2. JDK 21 with `JAVA_HOME` set. `keytool` comes with the JDK.
3. Both servers run on the same machine: API Manager on port 9443 and Identity Server on port **9444** (port offset 1).

If you already did Lab 13 (IS as Key Manager) with the same packs, the port offset and the certificate import are already done. Skip Step 1 and Step 4, and keep using the same packs.

Step 1: Start Identity Server on port 9444

1. Open `<IS_HOME>/repository/conf/deployment.toml` and add `offset = 1` to the existing `[server]` section:

   ```
   [server]
   hostname = "localhost"
   node_ip = "127.0.0.1"
   offset = 1
   ```

2. Start Identity Server: `wso2server.bat` (Windows) or `sh wso2server.sh` (Linux and macOS) from `<IS_HOME>/bin`.
3. Open the Console at `https://localhost:9444/console` and log in as `admin` / `admin`.

Step 2: Create the users and groups in Identity Server

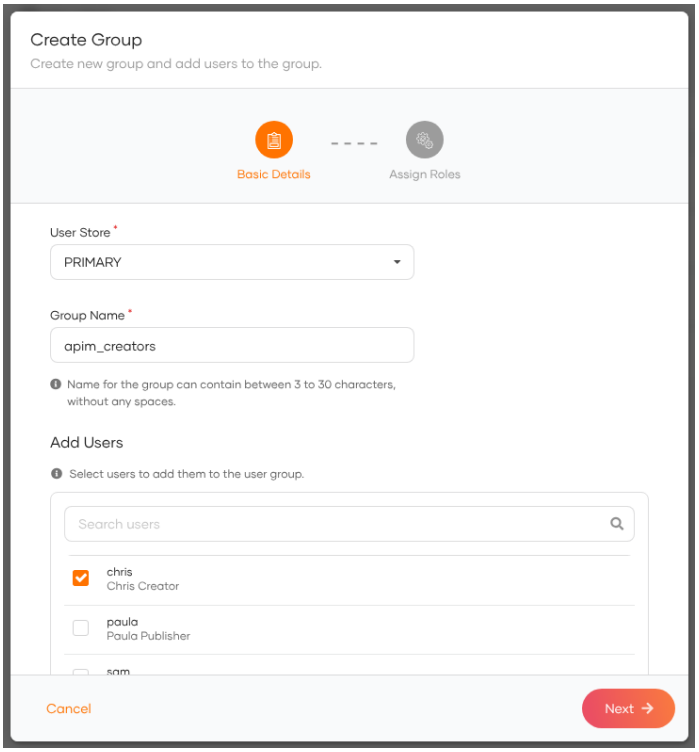
1. Go to **User Management > Users > Add User > Single User**. Create these three

CC BY 4.0

users. Select **Set a password for the user** and use the password `Wso2@1234` for each:

Username	First Name	Last Name	Email
chris	Chris	Creator	chris@example.com
paula	Paula	Publisher	paula@example.com
sam	Sam	Subscriber	sam@example.com

2. Go to **User Management > Groups > New Group**. Enter the group name `apim_creators`, **tick the checkbox** next to `chris` under **Add Users**, click **Next** and then **Finish**.

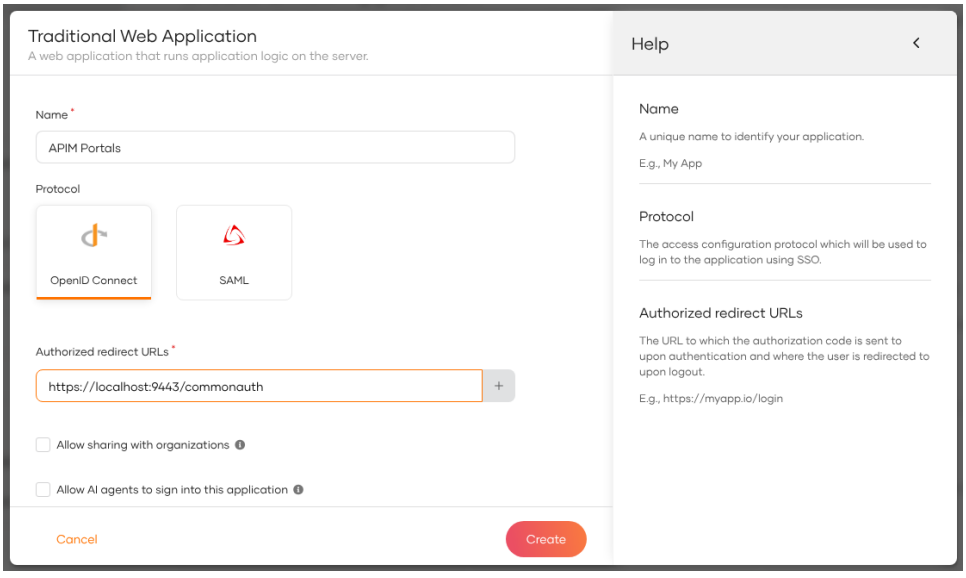


CC BY 4.0

3. In the same way, create `apim_publishers` with `paula` and `apim_subscribers` with `sam`.
4. Open each user and check the **Groups** tab. Each user must show its group. If a group is missing, click **Assign Group** on that tab and add it. A user without a group can log in but gets **Error 403: Forbidden** in the portals.

Step 3: Register API Manager as an application in Identity Server

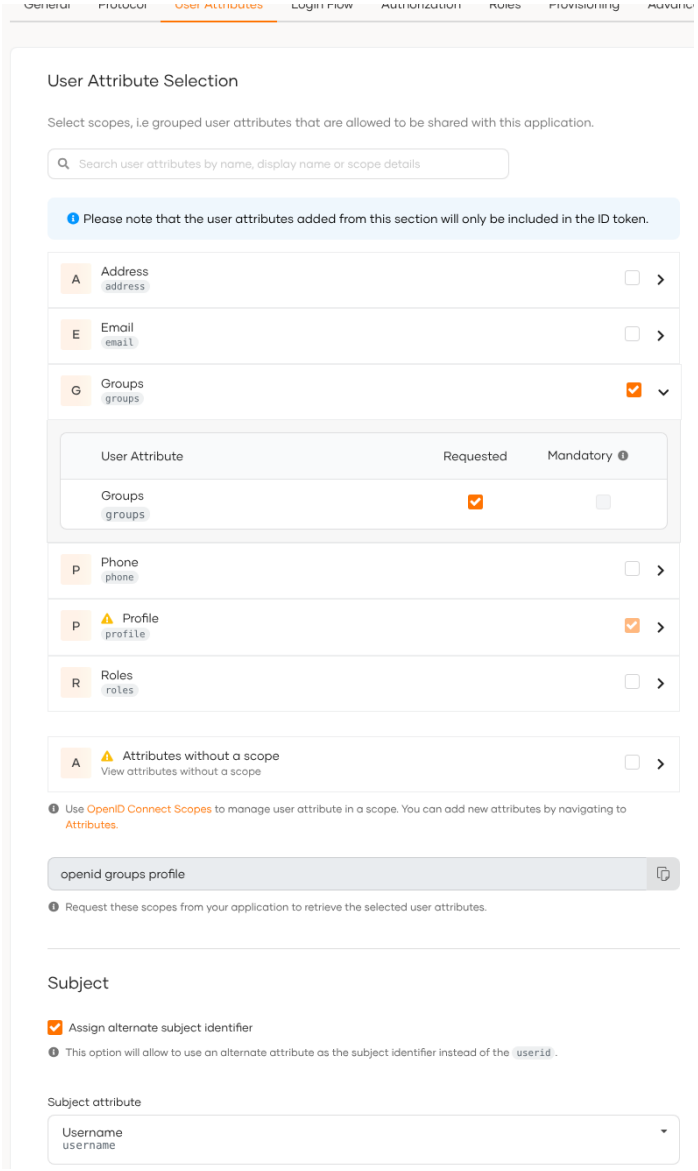
1. Go to **Applications**, click **+ New Application** and select **Traditional Web Application**.
2. Enter the name `APIM Portals`, select **OpenID Connect**, enter `https://localhost:9443/commonauth` as the **Authorized redirect URL** and click **Create**. This is the address on API Manager that receives the login response.



CC BY 4.0

3. On the **Protocol** tab, copy the **Client ID** and the **Client secret**. You need them in Step 5.
4. Go to the **User Attributes** tab:
    a. Tick the **Groups** scope, expand it and make sure **Groups** is ticked under **Requested**.
    b. Under **Subject**, tick **Assign alternate subject identifier** and select **Username** as the **Subject attribute**. API Manager then creates the user as `paula`, not as a long user ID.
    c. Click **Update**.

CC BY 4.0


General
Protocol
User Attributes
Login Flow
Authorization
Roles
Provisioning
User Attribute Selection
Select scopes, i.e grouped user attributes that are allowed to be shared with this application.
Search user attributes by name, display name or scope details
Please note that the user attributes added from this section will only be included in the ID token.
A Address address
E Email email
G Groups groups
User Attribute
Requested
Mandatory
Groups groups
P Phone phone
P Profile profile
R Roles roles
A Attributes without a scope
View attributes without a scope
Use OpenID Connect Scopes to manage user attribute in a scope. You can add new attributes by navigating to Attributes.
openid groups profile
Request these scopes from your application to retrieve the selected user attributes.
Subject
Assign alternate subject identifier
This option will allow to use an alternate attribute as the subject identifier instead of the userid.
Subject attribute
Username
username

CC BY 4.0

The box under the scopes shows `openid groups profile`. API Manager must ask for these scopes (Step 5).

Step 4: Make API Manager trust the Identity Server certificate

API Manager calls Identity Server over HTTPS (token endpoint and JWKS), so it must trust the Identity Server certificate. Run these commands with API Manager **stopped**. The keystore password is `wso2carbon`.

1. Export the certificate from Identity Server:

```
keytool -export -alias wso2carbon -file is7.crt -keystore <IS_HOME>/
repository/resources/security/wso2carbon.p12 -storetype PKCS12
-storepass wso2carbon
```

2. Import it into the API Manager truststore:

```
keytool -import -noprompt -alias wso2is7 -file is7.crt -keystore
<APIM_HOME>/repository/resources/security/client-truststore.jks
-storepass wso2carbon
```

   Each command is a single line, so it works the same in Windows Command Prompt and in a Linux or macOS terminal. If keytool says `alias <wso2is7> already exists`, the certificate was already imported in Lab 13. That is fine.

3. Start API Manager: `api-manager.bat` (Windows) or `sh api-manager.sh` (Linux and macOS) from `<APIM_HOME>/bin`. Wait for `WSO2 Carbon started`.

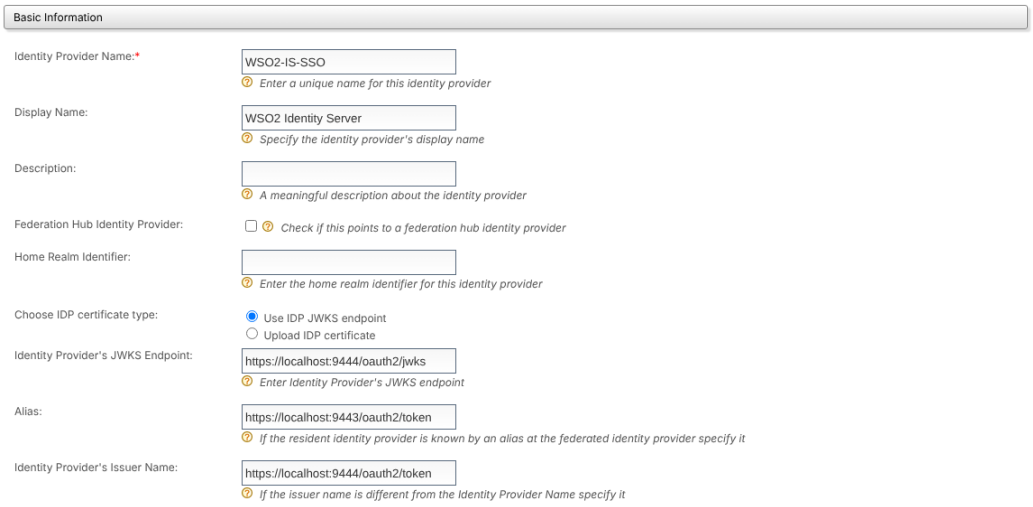
4. Open `https://localhost:9443/publisher` and `https://localhost:9443/devportal` once and log in as `admin` / `admin`. On a new pack this creates the `apim_publisher` and `apim_devportal` service providers that you change in Step 6. Log out again.

CC BY 4.0

Step 5: Add Identity Server as an identity provider in API Manager

1. Open the API Manager Management Console at `https://localhost:9443/carbon` and log in as `admin` / `admin`.
2. Go to **Main > Identity > Identity Providers > Add** and fill in **Basic Information**:

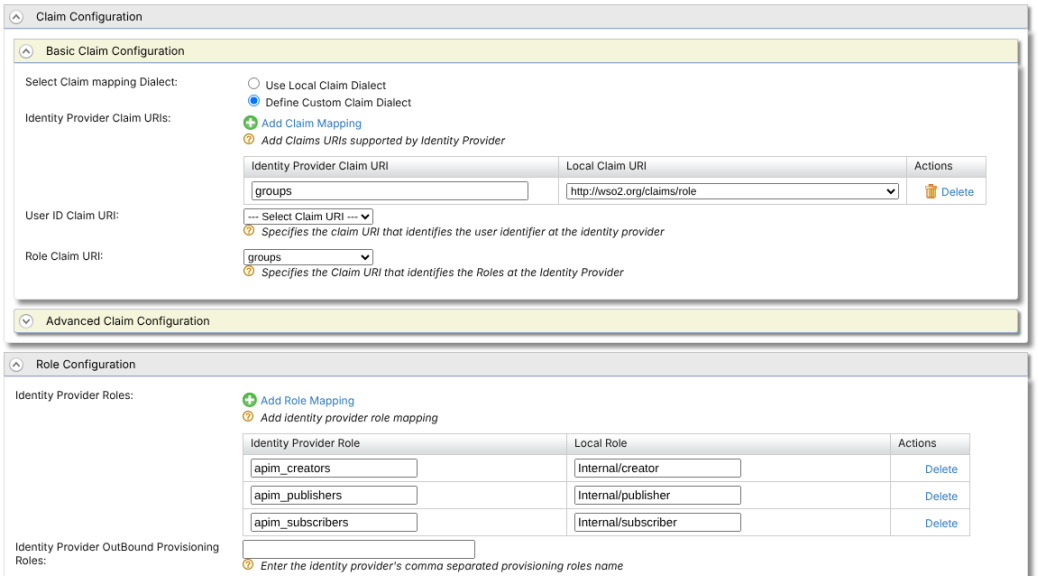
Field	Value
Identity Provider Name	WSO2-IS-SSO
Display Name	WSO2 Identity Server
Choose IDP certificate type	Use IDP JWKS endpoint
Identity Provider's JWKS Endpoint	https://localhost:9444/oauth2/jwks
Identity Provider's Issuer Name	https://localhost:9444/oauth2/token



CC BY 4.0

3. Expand **Claim Configuration > Basic Claim Configuration**:
    a. Select **Define Custom Claim Dialect**.
    b. Click **Add Claim Mapping**. Enter `groups` as the **Identity Provider Claim URI** and select `http://wso2.org/claims/role` as the **Local Claim URI**.
    c. Select `groups` as the **Role Claim URI**. This tells API Manager which claim holds the user's groups.
4. Expand **Role Configuration**. Click **Add Role Mapping** three times and enter:

Identity Provider Role	Local Role
apim_creators	Internal/creator
apim_publishers	Internal/publisher
apim_subscribers	Internal/subscriber



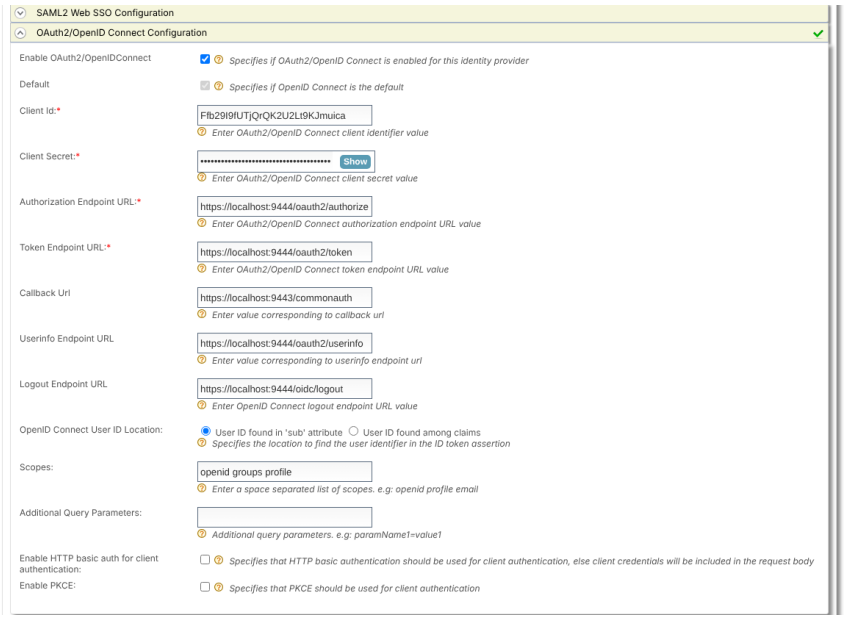
CC BY 4.0

5. Expand **Federated Authenticators > OAuth2/OpenID Connect Configuration** and enter:

Field	Value
Enable OAuth2/OpenIDConnect	Ticked
Default	Ticked
Client Id	Client ID from Step 3
Client Secret	Client secret from Step 3
Authorization Endpoint URL	https://localhost:9444/oauth2/authorize
Token Endpoint URL	https://localhost:9444/oauth2/token
Callback Url	https://localhost:9443/commonauth (already filled in)
Userinfo Endpoint URL	https://localhost:9444/oauth2/userinfo
Logout Endpoint URL	https://localhost:9444/oidc/logout
OpenID Connect User ID Location	User ID found in 'sub' attribute
Scopes	openid groups profile

Scopes must include `groups`. Without it, Identity Server does not send the groups and every user gets Error 403.

CC BY 4.0


SAML2 Web SSO Configuration
OAuth2/OpenID Connect Configuration
Enable OAuth2/OpenIDConnect
Specifies if OAuth2/OpenID Connect is enabled for this identity provider
Default
Specifies if OpenID Connect is the default
Client Id:*
Ffb29l9fUTjQrQK2U2Lt9KJmuica
Enter OAuth2/OpenID Connect client identifier value
Client Secret:*
Show
Enter OAuth2/OpenID Connect client secret value
Authorization Endpoint URL:*
https://localhost:9444/oauth2/authorize
Enter OAuth2/OpenID Connect authorization endpoint URL value
Token Endpoint URL:*
https://localhost:9444/oauth2/token
Enter OAuth2/OpenID Connect token endpoint URL value
Callback Url
https://localhost:9443/commonauth
Enter value corresponding to callback url
Userinfo Endpoint URL
https://localhost:9444/oauth2/userinfo
Enter value corresponding to userinfo endpoint url
Logout Endpoint URL
https://localhost:9444/oidc/logout
Enter OpenID Connect logout endpoint URL value
OpenID Connect User ID Location:
User ID found in 'sub' attribute
User ID found among claims
Specifies the location to find the user identifier in the ID token assertion
Scopes:
openid groups profile
Enter a space separated list of scopes. e.g: openid profile email
Additional Query Parameters:
Additional query parameters. e.g: paramName1=value1
Enable HTTP basic auth for client authentication:
Specifies that HTTP basic authentication should be used for client authentication, else client credentials will be included in the request body
Enable PKCE:
Specifies that PKCE should be used for client authentication

CC BY 4.0

6. Expand **Just-In-Time Provisioning**. Select **Always provision to User Store Domain** (`PRIMARY`) and **Provision silently**.



CC BY 4.0

7. Click **Register**. **WSO2-IS-SSO** is listed under **Identity Providers**.

Step 6: Use the identity provider for the Publisher and the Developer Portal

1. Go to **Main > Identity > Service Providers > List** and click **Edit** next to `apim_publisher`.
2. Expand **Local & Outbound Authentication Configuration**:
    a. Select **Federated Authentication** and select `WSO2-IS-SSO` in the list next to it.
    b. Tick **Assert identity using mapped local subject identifier**. API Manager then uses the local (provisioned) user and its mapped roles.
    c. Click **Update**.



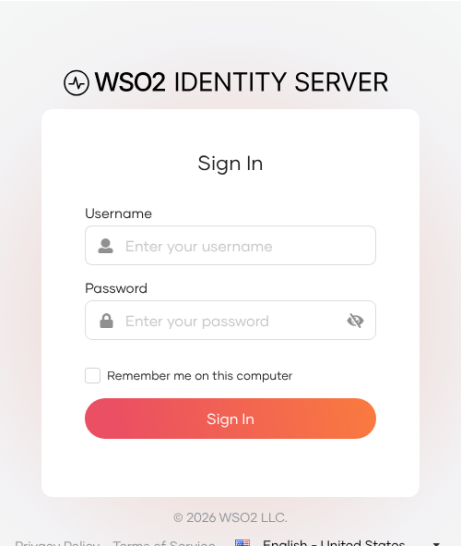
CC BY 4.0

3. Do the same for `apim_devportal`.

Try It

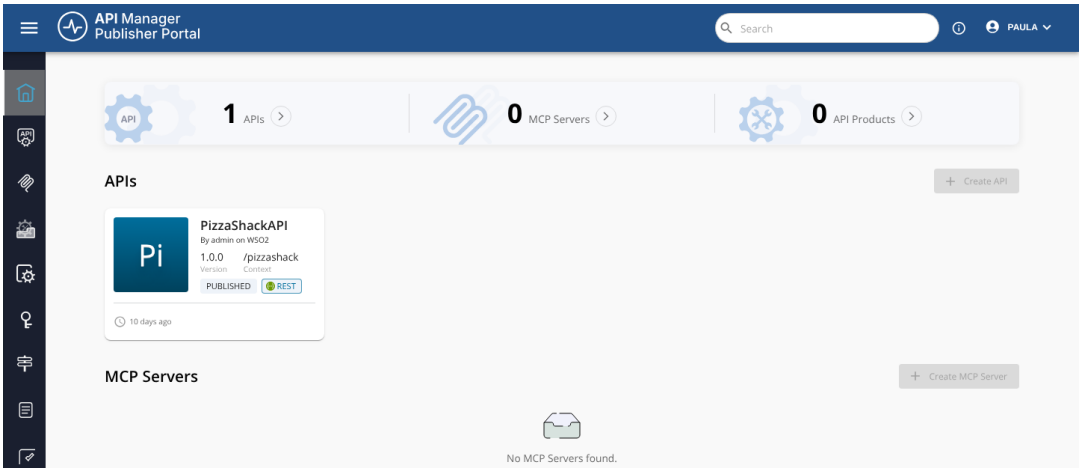
A. Publisher as paula (publisher)

1. Open a private browser window and go to `https://localhost:9443/publisher`.
2. You are sent to the Identity Server login page on port 9444. Log in as `paula` / `Wso2@1234`.



CC BY 4.0

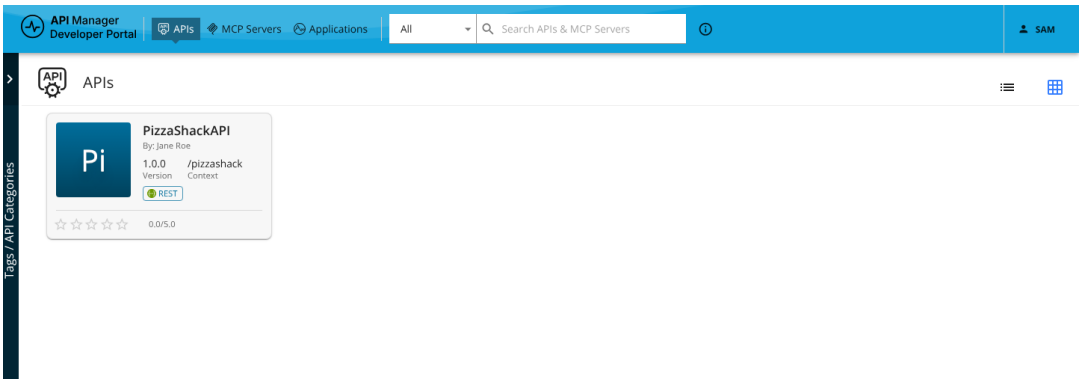
3. The Publisher opens with **PAULA** in the top-right corner.



CC BY 4.0

B. Developer Portal as sam (subscriber)

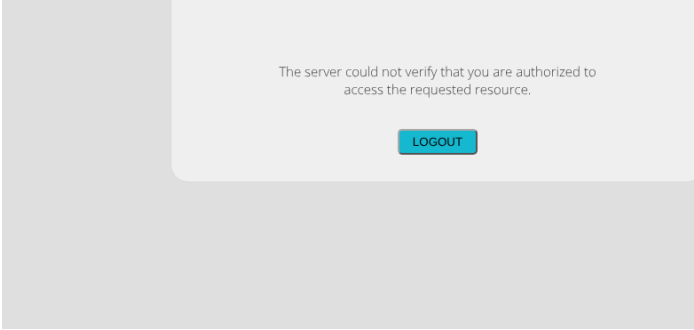
1. In a new private window, go to `https://localhost:9443/devportal` and click **Sign-in**.
2. Log in as `sam` / `Wso2@1234`. The Developer Portal opens with **SAM** in the top-right corner.



CC BY 4.0

C. A subscriber cannot open the Publisher

1. In a new private window, open `https://localhost:9443/publisher` and log in as `sam`. You get **Error 403: Forbidden**, because `apim_subscribers` maps only to `Internal/subscriber`.

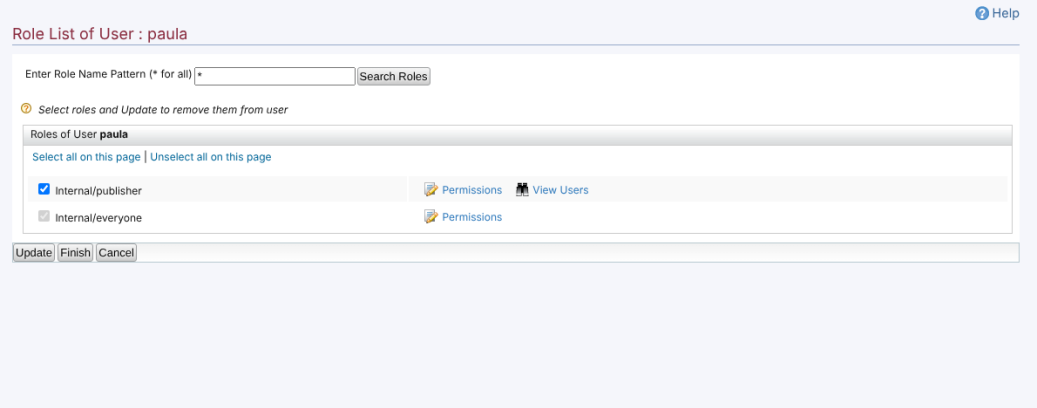


CC BY 4.0

2. Do the same as `chris`. The Publisher opens, because `apim_creators` maps to `Internal/creator`.

D. See the provisioned user in API Manager

1. In the Management Console (`https://localhost:9443/carbon`), go to **Main > Identity > Users and Roles > List > Users**. `paula`, `sam` and `chris` are listed: API Manager created them at their first login.
2. Click **View Roles** next to `paula`. `Internal/publisher` is ticked: it came from the role mapping.



CC BY 4.0

Roles are updated at every login. If you move a user to another group in Identity Server, the user gets the new role the next time they log in to a portal.

Troubleshooting

Problem	Cause and fix
Error 403: Forbidden after login	The user has no group in Identity Server (check the user's Groups tab), the Scopes field does not include groups (Step 5), the Groups attribute is not requested in the application (Step 3), or the role mapping names do not match the group names exactly.
The portal still shows the API Manager login page	Step 6 was not saved for that service provider, or Federated Authentication is not selected.
apim_publisher or apim_devportal is not in the Service Providers list	Open the Publisher and Developer Portal once as admin (end of Step 4) and refresh the list.
The user is created in API Manager with a long ID instead of the username	Assign alternate subject identifier is not ticked, or Username is not selected as the Subject attribute (Step 3).
PKIX path building failed / unable to find valid certification path in the API Manager log	The Identity Server certificate is not in the API Manager truststore, or API Manager was not restarted after the import (Step 4).
Identity Server shows "Redirect URI mismatch" (callback error)	The Authorized redirect URL in the application is not exactly https://localhost:9443/commonauth.
Address already in use: 9443 when Identity Server starts	offset = 1 is missing in the Identity Server deployment.toml (Step 1).

CC BY 4.0

CC BY 4.0